

EXECUTIVE SUMMARY

AI Recommendation System Regulatory Alignment Overview

Independent Research reference — architecture alignment with the FSC
AI Guideline (effective 2026-06-22) 7 principles (3-state honest)

Classification	Executive Summary
Date	June 2026 (reflecting the guideline’s entry into force)
Version	v2.0
Detailed Reference	Regulatory Compliance Framework Technical Reference v2.0

This is a 3–5 minute summary. It summarizes the architecture alignment of the PLE-based recommendation **reference system** (Independent Research) with the FSC Financial-Sector AI Guideline (effective 2026-06-22) 7 principles. **It is not a compliance attestation**; implementation status is distinguished honestly in three states — ● operational / ● implemented, not yet wired / ○ absent. For implementation details, code-level architecture, and clause-by-clause mappings, please refer to the ‘Regulatory Compliance Framework Technical Reference.’

System Overview

This is an AI system for Korea Post Financial check card product recommendations, built on a **heterogeneous-expert PLE (Progressive Layered Extraction)** multi-task learning architecture. It analyzes customer transaction history, demographics, and product holdings to simultaneously perform **12 prediction tasks** (churn signal, product stability, NBA, cross-sell, etc.). The trained deep learning model is **distilled** into LGBM (LightGBM) and served in real-time on AWS Lambda serverless infrastructure via a **3-layer fallback** (distilled LGBM → direct PLE → rule-based engine), ensuring the service never stops even under kill-switch activation. This architecture enables millisecond-level responses without GPU, achieving both model transparency and operational cost efficiency.

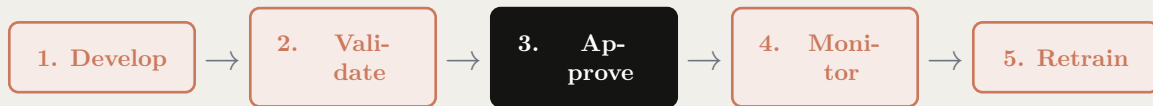
Regulatory Compliance Matrix

Regulation	Key Requirements	Implementation artifacts / wiring state	Status
Financial-Sector AI Guideline (eff. 2026-06-22, 7 principles)	Governance, legality, auxiliary nature reliability, financial stability, good faith, security 1. risk-assessment system (low/medium/high)	Training performance metrics, promotion human gate, PII hash are ● Risk assessment, fairness, explanation, kill switch, HITL are ● (depend on deployment wiring) Governance bodies, conflict-of-interest mechanisms are ○ (organizational/unimplemented)	partially-wired
Korea AI Basic Act (eff. 2026-01-22)	Prior notification of AI use (Art. 31) High-impact AI duties (Art. 34) Impact assessment (Art. 35)	AI disclosure module, KoreanFRIAssessor (7-dim) Proactively designed to high-impact AI level Periodic impact assessment is an organizational process	partially-wired
EU AI Act (High-risk: 2027.12)	Transparency/information (Art. 13) Human oversight (Art. 14) Accuracy/robustness/security (Art. 15)	Model cards + reason text, AnnexIVMapper Promotion human gate (auto_promote=false) Drift detection + prompt injection defense	partially-wired
Personal Information Protection Act (automated-decision refusal)	Right to refuse automated decisions (Art. 37-2) Pseudonymized data (Art. 28-2) Right to erasure (Art. 17)	Opt-out hook wired into serving (●) SHA-256 one-way hash + per-domain salt 30-day PII retention + encrypted-deletion policy	operational
Financial Consumer Protection Act, Credit Information Act	Suitability principle (FCPA §17) Duty to explain (FCPA §19) Automated-evaluation explanation (CIA §36-2)	Suitability filter (fail-closed when not assessed) Feature reverse-mapping + reason generation §36-2 explanation elements structured (depends on deployment wiring)	partially-wired

operational operational **partially-wired** implemented, not wired **absent** absent / organizational decision
(since multiple controls are mixed within one regulation row, the row tag is the representative state; see the middle column for the
mixed    detail)

Model Risk Management (MRM) Lifecycle

A 5-stage model lifecycle is designed, integrating SR 11-7 (US Fed/OCC), NIST AI RMF, and the Financial-Sector AI Risk Management Framework (AI RMF) delegated by the guideline.



Stage	Key Activities	System Components
1. Develop	Feature pipeline construction, model training, hyperparameter optimization	PipelineRunner + SageMaker Training
2. Validate	Independent performance evaluation, fairness audit, bias testing	Champion-Challenger comparison + FairnessMonitor
3. Approve	AI Risk Committee review, manual deployment approval	auto_promote=False (automatic deployment blocked)
4. Monitor	Drift detection, performance tracking, fairness metric measurement	PSI-based drift + DI/SPD/EOD daily measurement
5. Retrain	Automatic retrain trigger on threshold violation, retire underperforming models	Auto-retrain on 3 consecutive days of PSI exceedance

Key Safeguard: Offline Champion-Challenger Gate + Audit Chain

Stage 3 approval runs automatically through the `ModelCompetition.evaluate` offline gate: only challengers that improve the primary metric by at least `min_improvement` (default 0.5%) with no secondary metric degrading beyond `max_degradation` (default 2%) and no outstanding fidelity failures are promoted. Bootstrap and emergency rollback are handled through the `--force-promote` operator override. Every decision (`bootstrap` / `promote` / `reject` / `force_promote`) is written by `AuditLogger.log_model_promotion` to an HMAC-signed, hash-chained S3 WORM audit log, producing a non-repudiable record of who promoted what and why. The AI Risk Management Committee reviews the promotion outcome and the audit chain post-hoc.

Key Safeguards Summary

Before reading — status notation in this section

The safeguards below are controls whose **modules and logic are implemented**. Because this system has no production deployment and uses no production data, many are in an **implemented-but-not-yet-wired** (🟡) state, and only some run as **operational** (🟢) on the training/ingestion path. Phrases like “daily measurement” or “enforced on every prediction” express the **intended behavior once wired**, not an assertion of current operational effect.

Fairness Monitoring

Three fairness metrics (DI/SPD/EOD, corresponding to the guideline's Parity metrics) are **implemented to measure daily** across **5 protected attributes** (age group, gender, region type, income quintile, lifecycle stage) — , active once the prediction log loads protected attributes and outcome labels and is wired into serving.

Metric	Description	Threshold
DI (Disparate Impact)	Ratio of positive outcomes between groups	0.8 – 1.25
SPD (Statistical Parity Diff.)	Selection rate difference between groups	$ \text{SPD} \leq 0.1$
EOD (Equal Opportunity Diff.)	True positive rate difference between groups	$ \text{EOD} \leq 0.1$

Threshold violations automatically generate incidents; $\text{DI} < 0.6$ triggers a CRITICAL-level escalation.

Drift Surveillance

PSI (Population Stability Index) monitors feature, prediction, and label distribution shifts daily. When $\text{PSI} > 0.25$ persists for **3 consecutive days**, the automatic retraining pipeline is triggered. Per-feature PSI tracking enables early detection of individual feature shifts even when overall distribution appears stable.

Audit Trail

All decisions, changes, and access records are secured with **HMAC-SHA256 signatures + hash chains** to prevent tampering. S3 Object Lock (WORM) makes physical deletion impossible even for administrators, and regulatory audit logs are **immutably preserved for 7 years**. Seven DynamoDB audit tables (kill switch, consent, profiling, opt-out, incident, distillation, embedding) are in operation.

Kill Switch (Emergency Shutdown)

Level	Action	Fallback Strategy
Level 1	Immediate deactivation of problem model	Automatic rollback to previous approved version
Level 2	Serve rolled-back version	Escalate to Level 3 if rollback also fails criteria
Level 3	Deactivate all AI models	Switch to pre-defined rule-based recommendations

Granular shutdown is available at three scopes: GLOBAL (all) / PER_TASK (per task) / PER_CLUSTER (per customer segment).

Compliance Module

Four dedicated compliance components are designed to enforce regulatory obligations before a prediction is served ( — applied to every prediction once the deployment serving path is unified and wired to RecommendationService/lambda_handler):

Component	Responsibility
-----------	----------------

ConsentManager	Marketing consent lifecycle: grant / revoke / renew / per-channel verification
AIOptOut	AI decision refusal: registration, withdrawal, confirmation, immediate path switch
RegulatoryChecker	36-item pre-flight compliance check before each prediction is served
ProfilingRights	Data subject rights: access / correction / deletion / restriction / portability

Security: PII is masked before entering LLM pipelines. **PromptSanitizer** strips 8 injection patterns from all Bedrock prompts. **ComplianceAuditStore** records every prediction with full compliance context.

Customer Rights

Right	System Response
Opt-out (refuse AI decisions)	Immediate switch to human alternative path; full registration/withdrawal/confirmation lifecycle (AIOptOut)
Request explanation	Feature reverse-mapping + natural language recommendation reasons; internal SLA reply within 10 days (statutory 30 days, Enforcement Decree §44-3(5))
File objection	Automatic routing to agents by 7 reason types; P1 (1h) / P2 (4h) / P3 (24h) SLA
Right to erasure	30-day PII retention policy; encrypted deletion; S3 Lifecycle auto-applied

Detailed Reference Guide

For implementation details on each item, please refer to the corresponding section of the ‘**Regulatory Compliance Framework Technical Reference**.’

This Document	Technical Reference Section	Section
System Overview	Financial AI Regulatory Environment Overview	Ch. 1
Compliance Matrix – guideline	7-Principle Mapping – Guideline Check-Items and System Response	Ch. 2
Compliance Matrix – EU	EU AI Act Article Mapping (Art. 13/14/15, GDPR Art. 22)	Ch. 3
Compliance Matrix – AI Basic Act	Korea AI Basic Act High-Impact AI Classification	Ch. 4
Key Safeguards (Fairness / Drift / Audit / Kill Switch)	Compliance Architecture (3-Layer Structure Details)	Ch. 5
MRM Lifecycle	Model Risk Management (MRM) Framework	Ch. 7
Customer Rights	Human-in-the-Loop Design + Opt-out Management	Ch. 6
Governance Reporting	Automated Governance Report Generation (9 Sections + 36-Item Check)	Ch. 8

Governance Reporting Framework

Monthly/quarterly governance reports are **implemented to be auto-generated** (🟡 — operates once real-data supply and schedule wiring are in place). They comprise **9 sections**: fairness summary, drift summary, incident status, model change history, kill switch history, recommendation quality, risk trends, audit store summary, and executive summary. A 36-item regulatory compliance registry is designed to run a full quarterly check.

Bedrock Data Protection

Customer data is processed exclusively within the AWS Region (ap-northeast-2) during LLM invocation. Bedrock never transmits input/output data to model providers and never uses it for model training. VPC PrivateLink enables invocation without internet traversal, and CloudTrail audits all API calls. This structurally satisfies PIPA cross-border transfer restrictions and FSS data governance requirements.

On-Premises Environment

In air-gapped environments, all processing occurs locally with zero external data transfer. Uses Exaone 3.5 (Apache 2.0) + Qwen 14B (Apache 2.0) open-source models, maintaining the same regulatory compliance framework (checklists, audit logs, governance reports) as AWS.

Ops/Audit Agents

Practical enforcement of regulatory compliance is handled by two autonomous diagnostic agents. OpsAgent monitors pipeline performance and stability; AuditAgent audits fairness, regulatory compliance, and recommendation reason quality. 3-agent consensus with minority report preservation mitigates hallucination risk: a single FAIL vote escalates (a fail-safe that treats a missed risk as costlier than a false alarm) and every dissent is retained for audit traceability. All diagnostic results accumulate in a case store for regulatory audit evidence.

Detailed design: Design Document 11